

设置UID程序

版权所有 © 2017 杜文亮,保留所有权利。

允许个人使用。如需在课堂上使用这些习题,仅当该课程采用作者的著作作为教材时方可允许。所有其他用途均须事先征得作者的同意。

S2.1. Alice 运行一个由 Bob 拥有的 Set-UID 程序。该程序尝试从 /tmp/x 读取数据,该文件对 Alice 可读,但对其他人不可读。该程序能否成功从该文件读取数据?

S2.2. 一个进程尝试以读取方式打开一个文件。该进程的有效用户 ID 为 1000,实际用户 ID 为 2000。该文件对用户 ID 2000 可读,但对用户 ID 1000 不可读。该进程能否成功打开该文件?

S2.3. 由 root 用户拥有的 Set-UID 程序允许普通用户在执行该程序时获得 root 权限。什么可以防止用户利用该权限进行恶意操作?

S2.4. 我们正在尝试将种子用户拥有的程序 prog 转换为 Set-UID 程序。
该帐户由 root 用户拥有。运行以下命令能否实现目标?

```
$ sudo chmod 4755 prog $ sudo  
chown root prog
```

S2.5. 当 chown 命令更改 Set-UID 程序的拥有者时,它会自动禁用 Set-UID 位。请解释其原因。

S2.6. 调试程序时,我们可以在程序执行期间修改其内部变量,从而改变程序的行为。我们能否利用这种方法调试 Set-UID 程序并改变其行为?例如,如果程序原本应该打开 /tmp/xyz 文件,我们可以修改文件名字符串,使 Set-UID 程序最终打开 /etc/passwd 文件。

S2.7. system() 和 execve() 都可以用来执行外部程序。为什么?
system() 不安全,而 execve() 安全?

S2.8. 当程序从用户获取输入时,我们可以重定向输入设备,使程序可以从文件中获取输入。例如,我们可以使用 `prog < myfile` 将 myfile 中的数据作为输入提供给 `prog` 程序。现在,如果 `prog` 是一个 root 用户拥有的 Set-UID 程序,我们能否使用以下方法使这个特权程序从 `/etc/shadow` 文件中读取数据?

```
$ prog < /etc/shadow
```

S2.9. 当一个父进程 (使用 Set-UID 设置,有效用户 ID 为 root,实际用户 ID 为 bob)使用 fork() 创建子进程时,子进程会继承父进程的标准输入、输出和错误设备。即使子进程放弃 root 权限,它仍然保留对这些设备的访问权限。这似乎是一种权限泄漏,类似于本章讨论的权限泄漏情况。这会造成什么危险吗?

S2.10. ★

超级用户想要授予 Alice 使用 more 命令查看系统中所有文件的权限。他执行以下操作：

```
$ cp /bin/more /tmp/mymore $ sudo chown root /  
tmp/mymore $ sudo chmod 4700 /tmp/mymore
```

基本上,上述命令将 /tmp/mymore 变成了一个 Set-UID 程序。目前,由于权限设置为 4700,其他用户无法执行该程序。超级用户使用另一个命令 (如下所示)将执行权限仅授予 Alice。我们并非完全信任 Alice。Alice 只能读取其他用户的文件是可以接受的,但如果 Alice 能够获得超出此权限的任何权限,例如写入其他用户的文件,则是不可接受的。请阅读 more 程序的手册,了解 Alice 可以通过哪些操作来获得更多权限。

S2.11. 假设你有一个文件,你只允许其他用户读取该文件,前提是该用户的 ID

小于 1000。请描述一下如何才能真正实现这一点。

S2.12. 山姆发现了一个非常有用的网页,其中包含许多有趣论文的链接。他想下载这些论文。为了避免逐个点击链接,他编写了一个程序,该程序解析 HTML 网页,从网页中获取论文的 URL,然后使用名为 wget 的程序下载每个已识别的 URL。以下是代码片段:

```
char command[100]; char* line,  
url; line = getNextLine(file);  
从 HTML 文件中读取一行。 while (line != NULL) {  
  
    // 解析该行以获取 URL 字符串。url = parseURL(line); if (url != NULL){  
  
        // 构造一个命令并执行它 sprintf(command,  %s %s  ,  wget  , url);  
        system(command);  
  
    } line = GetNextLine(file);  
}
```

sprintf() 函数与 printf() 函数非常相似,区别在于 sprintf() 将输出放入由第一个参数指向的缓冲区,而 printf() 则将输出发送到显示器。请注意,getNextLine() 和 parseURL() 函数也是由 Sam 实现的 (此处未显示其代码)。wget 程序是 Unix 系统中的一个命令行程序,可用于从指定的 URL 下载网页文件。

网页所有者知道 Sam 在他的网页上做了什么;他想攻击 Sam 的程序。他知道上面的代码,但他不知道 Sam 是如何实现 GetNextLine() 或 ParseURL() 的,但他怀疑 Sam 可能在那里犯了一些错误。(1) 如果你是攻击者,请描述你的攻击计划。(2) 你如何解决这个问题?